

Google Cloud Security Project.

This is a capstone project done upon completion of the Google Cloud Cybersecurity certificate. The project covers an analysis and remediation of active vulnerabilities relating to a security incident.

Project Scenario

I am a Junior cloud security analyst at Cymbal Retail which has 170 stores, an online platform, serves 28 countries, and employs 80,400 workers. Its generated revenue in the previous fiscal year is \$15 billion. With numbers like these, the organization is committed to the safety and security of its customers, employees, and assets ensuring that internal and external regulatory compliance expectations are met. Unfortunately, after a massive data breach in the company, I am part of the security team that will help support through the lifecycle of the security incident.

Steps to be followed:

1. Identify vulnerabilities related to the breach
2. Isolate and contain breach to prevent further unauthorized access
3. Recover compromised systems
4. Remediate any outstanding compliance related issues
5. Verify compliance with frameworks

The Approach

1. Examine vulnerabilities and findings in Google cloud security command center
2. Shut Old Virtual Machine down and create a new Virtual Machine from a snapshot
3. Evoke public access to the storage bucket and switch to uniform bucket level access control
4. Limit firewall ports access and fix the firewall rules
5. Run a report to verify remediation of the vulnerabilities

I have attached the screenshots I took as I was tackling the project on the google cloud platform. After that, there is a series of events and more details about the breach. Finally, there is a comprehensive security report for the incident.

Dashboard - qwiklabs-gcp-04

console.cloud.google.com/home/dashboard?project=qwiklabs-gcp-04-de5d44990623&walkthrough_id=https%2F%2Fwww.skills.google%2Fdisplay_in_context%3Fdisplay_tok...

Google Cloud

qwiklabs-gcp-04-de5d44990623

Search (f) for resources, docs, products, and more

Dashboard Activity Recommendations

Project info

Project name: qwiklabs-gcp-04-de5d44990623

Project number: 981534416171

Project ID: qwiklabs-gcp-04-de5d44990623

Compute Engine

CPU (%)

Google Cloud Platform status

All services normal

Billing

Estimated charges: USD \$0.00

For the billing period Jul 1 - 21, 2026

Task 1. Analyze the data breach and gather information

One morning, the security team detects unusual activity within their systems. Further investigation into this activity quickly reveals that the company has suffered a massive security breach across its applications, networks, systems, and data repositories. Attackers gained unauthorized access to sensitive customer information, including credit card data, and personal details. This incident requires immediate attention and thorough investigation. The first step towards understanding the scope and impact of this breach is to gather information and analyze the available data.

In this task, you'll examine the vulnerabilities and findings in Google Cloud Security Command Center to determine how the attackers gained access to the data, and which remediation steps to take.

Important: The vulnerabilities listed in this section rely on specific security checks being run beforehand. If some checks haven't run yet, the related vulnerabilities might not appear in the Security Command Center when you complete the steps in

Previous Next

Security

Security Command Center

Compliance

Compliance detail

to view the state of your controls over time.

UTC-4 Jun 25, 2026 Jul 2, 2026 Jul 9, 2026 Jul 16, 2026

Filter Enter property name or value

Control	Status	Rule	Severity	Findings	Resources scanned
10.1	Non-compliant			29	
	Non-compliant	VPC Flow logs should be Enabled for every subnet in VPC Network	1	24	24
	Non-compliant	Firewall rule logging should be enabled so you can audit network access	10	4	4
	Non-compliant	Cloud Audit Logging should be configured properly across all services and all users from a project	1	1	1
	Compliant	Stackdriver Monitoring should be Enabled on Kubernetes Engine Clusters	1	0	-
10.2	Non-compliant			29	
	Non-compliant	VPC Flow logs should be Enabled for every subnet in VPC Network	1	24	24
	Non-compliant		10	4	4
	Non-compliant		1	1	1

Now viewing project "quiklabs-gcp-04-de5d44990623" in organization "No organization"

Google Cloud

qwiklabs-gcp-04-de5d44990623

Search (/) for resources, docs, products, and more

Search

🌟 📄 🔔 ⋮

S

Security

Security Command Cent...

- Overview
- Graph Search
- Issues
- Findings
- Assets
- Compliance
- Posture Management
- Rules
- Sources
- Settings

Detections and Controls

- Google SecOps
- Fraud Defense
- Model Armor
- Web Security Scanner
- Marketplace
- Release Notes

Findings

All Findings

AI Security

Vulnerabilities

Identity

Threats

Feedback

Learn

Get accurate attack exposure scores

The attack exposure scores on certain vulnerability and misconfiguration findings help you understand which of your high-value resources are most exposed to potential attacks. To improve the accuracy of the scores, replace the default high-value resource set with your own by creating one or more resource value configurations. [Learn more](#)

Create configurations

Query preview

state="ACTIVE" AND NOT mute="MUTED" AND NOT launch_state="LAUNCH_STATE_DEPRECATED...

Time range: Last 7 days

Quick filters

Clear all

1

Resource type

☐ Google Cloud resource manager project

5

☒ Google compute instance

5

☐ Google Cloud storage bucket

3

☐ Google compute network

2

☐ Google Cloud BigQuery table

1

Findings query results

Mute options

Export

Columns

Rows per page: 30 1 - 5 of 5

Google Cloud

qwiklabs-gcp-04-de5d44990623

Search (/) for resources, docs, products, and more

Search

🌟 📄 🔔 ⋮

S

Security

Security Command Cent...

- Overview
- Graph Search
- Issues
- Findings
- Assets
- Compliance
- Posture Management
- Rules
- Sources
- Settings

Detections and Controls

- Google SecOps
- Fraud Defense
- Model Armor
- Web Security Scanner
- Marketplace
- Release Notes

Findings

All Findings

AI Security

Vulnerabilities

Identity

Threats

Feedback

Learn

Get accurate attack exposure scores

The attack exposure scores on certain vulnerability and misconfiguration findings help you understand which of your high-value resources are most exposed to potential attacks. To improve the accuracy of the scores, replace the default high-value resource set with your own by creating one or more resource value configurations. [Learn more](#)

Create configurations

Query preview

state="ACTIVE" AND NOT mute="MUTED" AND NOT launch_state="LAUNCH_STATE_DEPRECATED...

Time range: Last 7 days

Quick filters

Clear all

1

Project ID

☐ qwiklabs-gcp-04-de5d44990623

3

Resource type

☐ Google Cloud resource manager project

5

☐ Google compute instance

5

☒ Google Cloud storage bucket

3

☐ Google compute

Findings query results

Mute options

Export

Columns

Category	Severity	Attack exposure score	Event time	Create time
☐ Public bucket ACL	High	0	July 21, 2026 at 12:13:15 PM UTC-4	July 21, 2026 at 12:13:15 PM UTC-4
☐ Bucket logging disabled	Low	0	July 21, 2026 at 12:13:12 PM UTC-4	July 21, 2026 at 12:13:13 PM UTC-4
☐ Bucket policy only disabled	Medium	0	July 21, 2026 at 12:13:12 PM UTC-4	July 21, 2026 at 12:13:13 PM UTC-4

Rows per page: 30 1 - 3 of 3

Google Cloud console showing the **Bucket details** page for the bucket `qwiklabs-gcp-04-de5d44990623_bucket`. The page displays information about public access, permissions, and inheritance.

Public access: Public access may be prevented by an organization policy. You need the `orgpolicy.policy.get` permission to confirm whether this bucket is public.

Permissions: One or more bucket-level permissions grant access to everyone on the internet (`allUsers`) account (`allAuthenticatedUsers`) account (`allAuthenticatedUsers`) publicly accessible, remove public access to this bucket.

Prevent public access to this bucket?

You are about to revoke all public access to the bucket `qwiklabs-gcp-04-de5d44990623_bucket` and its objects. This action:

- Overrides access granted to `allUsers` (including `allAuthenticatedUsers`) at both the bucket and object levels
- Restricts public sharing of existing and future resources
- Does not impact individual user permissions

Warning: This setting overrides public access on existing objects. Make sure none of your workloads will be interrupted by enforcement of this policy. [Learn more about this setting](#)

Permissions table:

Type	Principal	Role	Inheritance
☐	981534416171@cloudbuild.gserviceaccount.com	Legacy Cloud Build Service Account	Cloud Build Service Account
☐	<code>allUsers</code>	Storage Legacy Bucket Reader	<code>qwiklabs-gcp-04-de5d44990623</code>
☐	Editors of project: <code>qwiklabs-gcp-04-de5d44990623</code>	Storage Legacy Bucket Owner	
☐	Owners of project: <code>qwiklabs-gcp-04-de5d44990623</code>	Storage Legacy Bucket Owner	
☐	<code>qwiklabs-gcp-04-de5d44990623.iam.gserviceaccount.com</code>	Storage Admin	<code>qwiklabs-gcp-04-de5d44990623</code>

Instance deleted notification: Instance deleted

Google Cloud console showing the **Security** page, specifically the **Compliance** section. The page displays a grid of compliance frameworks and their status.

Compliance Frameworks:

- 100% passing (View details)
- 82% passing (View details)
- 82% passing (View details)
- ISO 27001 2013: 69% passing (View details)
- ISO 27001 2022: 87% passing (View details)
- NIST 800-53 R4: 62% passing (View details)
- NIST 800-53 R5: 85% passing (View details)
- NIST CSF 1.0: 75% passing (View details)
- OWASP 2017: 100% passing (View details)
- OWASP 2021: 100% passing (View details)
- PCI DSS 3.2.1: 90% passing (View details)
- PCI DSS 4.0: 88% passing (View details)
- SOC2 2017: 61% passing (View details)

Notifications:

- You can now search for documentation, resource metadata, tutorials, and API keys
- Now viewing project "qwiklabs-gcp-04-cd3cfb8d69c" in organization "No organization"

The 5 W's of the data breach

What happened?

The security team at Cymbal Retail detected unusual activity within the cloud environment. Upon further investigation, it was confirmed that a significant compromise had occurred. The breach resulted in the exposure of credit card information—including the card numbers, user names, and associated locations—for a substantial number of users. The security team quickly got to work to investigate the security incident, gather information, and analyze all available log data to understand the scope of the breach and its impact.

Who was involved?

The security team at Cymbal Retail was unable to attribute the perpetrator of the data breach.

When did it happen?

The security team is still undergoing forensic analysis to determine the exact times related to the breach.

Where did it happen?

This security incident occurred on Cymbal Retail's cloud environment, where multiple cloud resources were affected.

Why did it happen?

The data breach happened because the malicious actor was able to exploit vulnerabilities in Cymbal Retail's cloud resources, including an insecurely configured firewall, bucket, and virtual machine (VM).

The cc-app-01 VM became infected with malware. The VM was configured with a public IP address and open SSH and RDP ports. This allowed the malicious actor to establish a connection through the open ports. The VM contained a default service account which had full access to APIs, and the malicious actor was able to successfully compromise the default service account, granting them unauthorized access into the VM.

The malicious actor then escalated their privilege and gained access to the service account's managed user key. This allowed them to further escalate the attack and target other services. Leveraging the compromised credentials, the malicious actor targeted BigQuery, where they successfully gained access to sensitive credit card information. To facilitate data exfiltration, the attacker identified and utilized a publicly accessible storage bucket with public internet access enabled. They then exfiltrated the credit card information.

Timeline

The following timeline is based on the available information and forensic analysis conducted during the investigation and details the malicious actor's attack path into the cloud environment.

1. Initial compromise

The initial compromise happened when the malicious actor identified the open and public SSH and RDP ports for the vulnerable application VM cc-app-01.

2. Unauthorized access

The malicious actor then established a connection through the open SSH and RDP ports to gain unauthorized access to the VM cc-app-01. The malicious actor used a brute-force attack to compromise weak credentials and successfully infiltrate the system.

3. Malware

The malicious actor infected the VM with malware to maintain their persistence in the VM.

4. Privilege escalation

The malicious actor gained access into the VM cc-app-01, where they explored the system and identified a user-managed service account key. The presence of this key enabled the malicious actor to compromise both user and service account credentials, granting them unauthorized access. By compromising the user and service account credentials, the attacker escalated their privilege and gained broader access within the Cymbal Retail cloud network.

5. Targeting BigQuery

The malicious actor then identified the service BigQuery, which contained sensitive customer data. Leveraging the compromised credentials, the malicious actor exploited the compromised credentials to gain unauthorized access to BigQuery.

6. Data exfiltration

The malicious actor identified non-encrypted credit card information stored within the compromised system. To facilitate data exfiltration, the attacker utilized a storage bucket that had public internet access enabled. They exfiltrated the credit card information, exporting it for later retrieval.

Vulnerabilities and remediation

The following vulnerabilities were identified and remediated for the affected storage bucket, virtual machine, and firewall.

Storage bucket

The findings in the following table indicate that the storage bucket was insecurely configured to be publicly accessible, lacked appropriate access controls, and did not have proper logging enabled. All of these vulnerabilities exposed the data stored in the bucket to unauthorized access.

Storage bucket			
Severity	Vulnerability	Corresponding compliance rule	Remediation actions
High	Public bucket ACL	Cloud Storage buckets should not be anonymously or publicly accessible.	To address the storage bucket vulnerability, public access to the storage bucket was removed. Fine-grained access was replaced with uniform bucket-level access control to ensure uniform access to all objects in the bucket by using only bucket-level permissions.
Medium	Bucket policy only disabled	N/A	
Low	Bucket logging disabled	N/A	

Virtual machine

The findings in the following table indicate that the virtual machine was insecurely configured with a public IP address, which allowed anyone on the internet to connect to it. The VM was also configured with no secure boot, which allowed the VM to potentially run unauthorized software during the boot process. The VM also used a default service account, which increased the attack surface of the VM. Lastly, the VM was granted full access to all APIs and connected to a known, malicious domain. All of these vulnerabilities and misconfigurations contributed to the data breach and enabled unauthorized access to a malicious actor.

Virtual machine (VM)			
Severity	Vulnerability	Corresponding compliance rule	Remediation actions
High	Public IP address	VMs should not be assigned public IP addresses.	To address the VM vulnerabilities, the infected VM cc-app-01 was shut down and deleted. A new VM, named cc-app-02, was created from a known and trusted snapshot, configured to use a private IP address, and enabled with secure boot.
Medium	Compute secure boot disabled	N/A	
Medium	Default service account used	N/A	
Medium	Full API access	Instances should not be configured to use the default service account with full access to all Cloud APIs.	
Low	Malware: bad domain	N/A	

Firewall

The findings in the following table indicate that the firewall was insecurely configured with open SSH and RDP ports, which allowed unrestricted access to SSH and RDP. The firewall also did not have firewall logging enabled, preventing the recording of information about network connections.

Firewall			
Severity	Vulnerability	Corresponding compliance rule	Remediation action
High	Open SSH port	Firewall rules should not allow connections from all IP addresses on TCP or SCTP port 22.	To address the firewall vulnerabilities, the firewall rules were adjusted to restrict SSH access to only the internal IP range 35.235.240.0/20, and firewall logging was enabled.
High	Open RDP port	Firewall rules should not allow connections from all IP addresses on TCP or UDP port 3389.	
Medium	Firewall rule logging	Firewall rule logging should be enabled so you can audit network access.	

Cymbal Retail Security Incident Report

Executive summary

The security team detected unusual activity within the cloud systems. Further investigation into this activity quickly reveals that the company has suffered a massive security breach across its applications, networks, systems, and data repositories. Attackers gained unauthorized access to sensitive customer information, including credit card data and personal details.

The incident involved the infection of one of the application VMs by malware. The infected VM had SSH and RDP services enabled, with a public IP allowing the attacker to establish a connection through those ports.

It was discovered that the VM instance was created with the default service account, which had full access to cloud APIs. This configuration, combined with potentially excessive IAM roles assigned to user(s) accessing the instance, posed a risk of privilege escalation.

Subsequently, the attacker exploited the compromised machine to gain access to the service account's managed user key. This allowed them to further escalate the attack and target other services. Specifically, the attacker leveraged the compromised user credentials to exfiltrate unencrypted credit card information.

During the course of the attack, the perpetrators identified a storage bucket with public access enabled from the internet. Moreover, the bucket had fine-grained access control, allowing the use of both IAM and ACLs at both the bucket and individual object levels.

Investigation

A comprehensive investigation was conducted to determine the nature and extent of the compromise. The following findings were identified:

1. Malware infection: Forensic analysis confirmed the presence of malware on the compromised VM. The specific type and variant of the malware were identified through in-depth analysis, providing insights into the attacker's techniques and potential motivations.

2. Unauthorized access: Evidence revealed that the attacker gained unauthorized access to the compromised VM by exploiting open RDP and SSH services. The access logs and network traffic analysis provided crucial insights into the attacker's entry point and their subsequent activities.

3. Privilege escalation: The forensic examination indicated that the attacker leveraged the compromised VM to escalate privileges and gain access to sensitive systems and resources. Through the exploitation of user and service account credentials, the attacker was able to move laterally within the network and target additional services; in particular gaining unauthorized access to BigQuery.

4. Data exfiltration: The forensic analysis confirmed the exfiltration of credit card information, including card numbers, user names, and associated locations. The attacker utilized a storage bucket with public internet access to initiate and facilitate the exfiltration, exporting the compromised data for later remote retrieval.

The findings provide valuable insights into the attack, enabling the incident response team to understand the attack vector, the attacker's actions, and the compromised data. These findings will serve as crucial evidence for further investigations, remediation efforts, and future cybersecurity enhancements.

Response and remediation

To effectively remediate the incident, a series of actions were taken in alignment with industry best practices. The following outlines the containment, eradication, and recovery measures implemented:

Containment and eradication measures

1. **Isolate of compromised VM:** The compromised VM cc-app-01 was immediately isolated from the network to prevent further unauthorized access and limit its impact on other systems.
2. **Restrict RDP and SSH access:** Firewall rules were promptly updated to restrict RDP and SSH access to the compromised VM, minimizing the potential for further exploitation through these services.
3. **Remove public storage bucket:** Public access to the storage bucket was removed and permissions for the bucket were changed to uniform bucket-level access.

Recovery measures

1. **Restore from trusted snapshot:** The compromised VM was restored from a trusted snapshot taken prior to the incident, ensuring a clean and secure state.
2. **Review security configuration:** A comprehensive review of security configurations was conducted across systems—including VMs, storage buckets, and network infrastructure—to identify and rectify any misconfigurations or weaknesses.
3. **Improve monitoring:** Monitoring mechanisms were strengthened, including the implementation of real-time log analysis to enable prompt identification of any future unauthorized access attempts or suspicious activities.

By implementing these measures, the security team successfully mitigated the immediate risks, removed the attacker's presence, and restored affected systems to a secure and operational state.

Recommendations

This incident provided valuable lessons that can inform future cybersecurity practices and help prevent similar incidents. The following are recommendations that we suggest be implemented to mitigate similar attacks from happening in the future:

- 1. Conduct regular risk assessments:** Perform periodic risk assessments to identify and prioritize potential security risks and vulnerabilities specific to your organization. This includes assessing systems, networks, applications, and data assets.
- 2. Implement multi-factor authentication (MFA):** Enable MFA for all critical systems and accounts to add an extra layer of security. This measure helps protect against unauthorized access, even if passwords are compromised.
- 3. Implement the principle least privilege:** Follow the principle of least privilege, granting users only the permissions necessary to perform their job functions. Regularly review user privileges and remove unnecessary access rights.
- 4. Conduct penetration testing:** Regularly perform penetration testing and vulnerability assessments to identify and address security weaknesses. This measure helps uncover vulnerabilities before malicious actors exploit them.